Light

Cyber Security — Threats

Over **1,100,000+ marks** of exam-aligned content across **67 qualifications**. 4,200+ auto-marked assessments & long-answer practice. No login required.

Assessment Hub | Notes / Textbook | Long-Answer Practice

Assessment Hub
Long-Answer
Notes Index
What you must know
Toolkit
1. Threats and vulnerabilities
2. Social engineering and malware
3. Prevention and detection
Worked examples
Quick reference
Typical pitfalls

AQA GCSE Computer Science — **Cyber Security (8525 Paper 2)**. This topic covers cyber security fundamentals, threats including social engineering and malware, penetration testing, and methods to detect and prevent cyber attacks.
Exam questions typically ask you to **define** cyber security terms, **describe** how different threats work, **explain** how to protect against attacks, and **compare** different forms of malware or social engineering. Expect questions worth 2—6 marks requiring both factual recall and applied understanding.

Why cyber security matters

Cyber security is one of the most important topics in modern computing. As our lives become increasingly digital — banking, shopping, healthcare, education, and communication all happening online — the need to protect our data and systems from attack has never been greater. Understanding cyber security helps you:

- **Protect yourself:** Recognise phishing emails, create strong passwords, and avoid common scams
- **Understand the news:** Data breaches and cyber attacks regularly make headlines — this topic helps you understand what's happening

- **Future careers:** Cyber security is one of the fastest-growing fields in computing, with excellent career prospects
- **Responsible computing:** Understanding threats helps you use technology safely and responsibly

The AQA specification requires you to understand different types of cyber threats, how attackers exploit human psychology (social engineering) and software vulnerabilities, and the methods used to detect and prevent attacks.

What you must know

This checklist covers the key exam-visible concepts from the AQA specification. You should be able to define, describe, and explain each point.

- **Define** cyber security and describe its main purposes.
- **Explain** the following cyber security threats: social engineering, malware, pharming, weak/default passwords, misconfigured access rights, removable media, unpatched/outdated software.
- **Explain** what penetration testing is, including the two types (insider and external).
- **Define** social engineering and describe how to protect against it.
- **Explain** the following forms of social engineering: blagging (pretexting), phishing, shouldering (shoulder surfing).
- **Define** malware and describe how to protect against it.
- **Describe** how the following forms of malware work: computer virus, trojan, spyware.
- **Explain** the following security measures: biometric measures, password systems, CAPTCHA, email confirmations, automatic software updates.

> **Specification note.** AQA 8525 assesses cyber security on Paper 2 (Computing concepts). Questions often ask you to describe threats (what they are and how they work) and explain prevention methods. The most common exam questions focus on social engineering (especially blagging vs phishing) and malware (virus vs trojan vs spyware).

Toolkit

Cyber security threats at a glance

Threat	What it is	How it works
Social engineering	Manipulating people to give up information	Tricks humans rather than exploiting software
Malware	Malicious software	Software designed to damage or gain unauthorised access
Pharming	Redirecting to fake websites	Changes DNS settings to send users to fraudulent sites
Weak passwords	Easy-to-guess credentials	Allows attackers to brute-force or guess passwords

Threat	What it is	How it works
Misconfigured access	Wrong permissions set	Users have more access than they need
Removable media	USB drives, external disks	Can introduce malware or steal data
Unpatched software	Outdated programs	Known vulnerabilities remain unfixed

Social engineering methods

Method	Definition	Key characteristics
Blagging (pretexting)	Creating a fake scenario to trick a specific person	Targets an **individual**; uses an invented story; often impersonates authority
Phishing	Fraudulently obtaining information via email/SMS	Targets **many people**; disguised as reputable source; contains links to fake sites
Shouldering	Observing someone's private information over their shoulder	Physical observation; watching PIN entry, passwords, or screens

Types of malware

Type	How it works	Key characteristic
Virus	Attaches to a program/file; spreads when executed	Requires user to run the infected file; **self-replicates**
Trojan	Disguises itself as legitimate software	User is **tricked into installing**; appears useful but is malicious
Spyware	Secretly gathers information about user activity	Runs **without user's knowledge**; sends data to attacker

Prevention methods summary

Method	What it does	What it protects against
Biometric measures	Uses physical characteristics (fingerprint, face, iris)	Unauthorised access; identity theft
Password systems	Requires knowledge of secret credentials	Unauthorised access
CAPTCHA	Tests that user is human, not a bot	Automated attacks; bot account creation
Email confirmations	Verifies user has access to claimed email	Fake account creation; identity fraud
Automatic updates	Installs security patches automatically	Exploitation of known vulnerabilities

Penetration testing types

White box (insider test)

- Tester has knowledge of the system
- May have basic credentials
- Simulates a **malicious insider** attack
- Tests what a rogue employee could do

Black box (external test)

- Tester has **no knowledge** of the system
- No credentials provided
- Simulates an **external attacker**
- Tests what an outside hacker could do

1. Cyber security threats and vulnerabilities

1.1 What is cyber security?

Cyber security consists of the processes, practices, and technologies designed to protect networks, computers, programs, and data from attack, damage, or unauthorised access. It encompasses everything from the technical measures that protect computer systems to the policies and training that help people avoid falling victim to attacks.

The main purposes of cyber security are to:

- **Protect data:** Keep sensitive information confidential and prevent it from being stolen or corrupted
- **Ensure availability:** Make sure systems and data remain accessible when needed
- **Maintain integrity:** Ensure data hasn't been tampered with or altered without authorisation
- **Prevent unauthorised access:** Stop attackers from gaining access to systems they shouldn't use

Cyber security is not just about technology — it's also about people and processes. Many attacks succeed not because of software flaws, but because humans make mistakes or are tricked into giving away information.

1.2 Common cyber security threats

The AQA specification identifies several key threats that you need to understand. These threats can be broadly categorised into those that target people (social engineering), those that target software (malware and exploitation), and those that result from poor security practices.

Pharming

Pharming is a cyber attack intended to redirect a website's traffic to a fake website. Unlike phishing (which tricks users into clicking fake links), pharming works by manipulating the system that converts website names into addresses (DNS). When successful, users think they're visiting a legitimate website but are actually on a fraudulent copy designed to steal their information.

For example, a pharming attack might redirect users trying to visit their bank's website to an identical-looking fake site. When users enter their login details, the attackers capture them.

Weak and default passwords

Weak passwords are easy to guess — things like "password123", "qwerty", or dates of birth. **Default passwords** are the passwords that devices come with from the manufacturer, like "admin" or "1234". Both create serious security vulnerabilities because attackers can easily guess them or find lists of default passwords online.

Attackers use automated tools that can try thousands of common passwords per second. If your password is weak or unchanged from the default, your account or device can be compromised in seconds.

Misconfigured access rights

Misconfigured access rights occur when users are given more permissions than they need to do their job. This violates the principle of "least privilege" — that users should only have access to what they absolutely need.

For example, if a junior employee accidentally has administrator access to the entire company network, they could accidentally (or deliberately) cause serious damage. Even if that employee wouldn't misuse their access, if their account is compromised, the attacker gains all those unnecessary permissions.

Removable media

Removable media such as USB drives, external hard drives, and memory cards can be a significant security threat. They can:

- Introduce malware into a network when plugged in (some malware is designed to spread via USB)
- Be used to steal data by copying files from secure systems
- Be lost or stolen, exposing any sensitive data stored on them

A famous example is the Stuxnet attack, where malware was reportedly introduced to an air-gapped (not connected to the internet) facility via infected USB drives.

Unpatched and outdated software

Unpatched software is software that hasn't been updated with the latest security fixes. When security researchers or attackers discover vulnerabilities in software, the developers release patches (updates) to fix them. If users don't install these patches, their systems remain vulnerable to known attacks.

Outdated software is software that is no longer supported by its developer, meaning no new security patches will be released. Running outdated software means any newly discovered vulnerabilities will never be fixed.

Many major cyber attacks have exploited known vulnerabilities that patches were available for — the victims simply hadn't updated their systems. This is why automatic updates are so important.

1.3 Penetration testing

Penetration testing (often called "pen testing") is the process of attempting to gain access to resources without knowledge of usernames, passwords, or other normal means of access. Organisations hire ethical hackers to test their security by trying to break into their own systems — it's better to find vulnerabilities before malicious attackers do.

The AQA specification requires you to understand two types of penetration testing:

White box testing (insider simulation): The tester has knowledge of the system and possibly basic credentials. This simulates an attack from a **malicious insider** — someone who already works within the organisation. This tests what damage a disgruntled employee or someone with stolen employee credentials could do.

Black box testing (external simulation): The tester has **no knowledge** of the system and no credentials. This simulates an attack from an **external attacker** — someone trying to break in from outside with no inside information. This tests how vulnerable the organisation is to attacks from unknown hackers.

Penetration testing helps organisations understand their vulnerabilities, test their security measures, and identify what needs to be improved before real attackers find the same weaknesses.

Worked Example 1 – Defining cyber security

Question: Define the term cyber security. [2 marks]

Model answer:
Cyber security consists of the processes, practices, and technologies **(1)** designed to protect networks, computers, programs, and data from attack, damage, or unauthorised access **(1)**.

Exam tip: This is a specification definition that examiners expect verbatim. Memorise: "processes, practices, and technologies" + "protect from attack, damage, or unauthorised access."

Worked Example 2 – Explaining pharming

Question: Explain what pharming is. [2 marks]

Model answer:
Pharming is a cyber attack that redirects a website's traffic to a fake/fraudulent website **(1)**. Users think they are visiting a legitimate site but their information is captured by attackers **(1)**.

Exam tip: Pharming is about redirecting traffic — don't confuse it with phishing (which tricks users into clicking links). Pharming changes where website names point to.

Worked Example 3 – Penetration testing types

Question: Describe two types of penetration testing. [4 marks]

Model answer:
White box/insider testing: The tester has knowledge of the system and possibly basic credentials **(1)**. This simulates an attack from a malicious insider/employee **(1)**.
Black box/external testing: The tester has no knowledge of the system and no credentials **(1)**. This simulates an attack from an external attacker/hacker **(1)**.

Exam tip: The key distinction is knowledge: insider tests have knowledge/credentials, external tests have none. Link each to what it simulates (insider = malicious employee, external = outside hacker).

Worked Example 4 – Unpatched software threat

Question: Explain why unpatched software is a cyber security threat. [2 marks]

Model answer:
Unpatched software contains known security vulnerabilities that haven't been fixed **(1)**. Attackers can exploit these known weaknesses to gain unauthorised access or cause damage **(1)**.

Exam tip: Emphasise that vulnerabilities are "known" — patches exist but haven't been applied. This is different from zero-day attacks (which exploit unknown vulnerabilities).

2. Social engineering and malware

2.1 What is social engineering?

Social engineering is the art of manipulating people so they give up confidential information. Rather than exploiting software vulnerabilities, social engineering exploits human psychology — our tendency to trust, help others, or follow authority figures. Social engineering attacks target the "human element" of security because people are often the weakest link. Even the most sophisticated technical security can be bypassed if

someone can be tricked into revealing their password or letting an attacker into a secure building.

Protecting against social engineering:

- Be suspicious of unsolicited requests for information, even if they seem to come from trusted sources
- Verify the identity of anyone asking for sensitive information through a separate channel
- Never give out passwords, PINs, or security codes to anyone
- Be aware of the techniques attackers use (blagging, phishing, shouldering)
- Regular security awareness training for staff

2.2 Forms of social engineering

Blagging (pretexting)

Blagging is the act of creating and using an invented scenario to engage a targeted victim in a manner that increases the chance the victim will divulge information or perform actions that would be unlikely in ordinary circumstances.

Key characteristics of blagging:

- **Targets an individual:** The attacker researches and focuses on one specific person
- **Uses a convincing story:** The attacker creates a believable scenario, often impersonating someone in authority
- **Builds trust:** The attacker may spend time establishing credibility before asking for information

Example: An attacker calls the IT helpdesk pretending to be a senior manager who has forgotten their password. They use details gathered from social media to make the story convincing: "This is John from the marketing department — I know I should know this but I've just got back from the conference in Manchester and I really need to access my files for the board meeting in an hour. Can you reset my password?"

Phishing

Phishing is a technique of fraudulently obtaining private information, often using email or SMS. Phishing messages are disguised to look as though they come from a reputable source (like a bank, online service, or colleague) and typically try to get victims to click a link or provide sensitive information.

Key characteristics of phishing:

- **Targets many people:** Sent to large numbers hoping some will respond
- **Disguised as legitimate:** Appears to be from a trusted organisation
- **Contains links:** Often directs victims to fake websites that look real
- **Creates urgency:** Often claims immediate action is needed ("Your account will be closed")
- **Uses email, SMS, or social media:** Can come through multiple channels

Example: An email that appears to be from a bank stating "We have detected suspicious activity on your account. Click here to verify your details within 24 hours or your account will be suspended." The link goes to a fake banking website that captures login credentials.

> **Blagging vs Phishing — key difference for exams:**
> **Blagging** targets a **specific individual** using a personalised, invented scenario.
> **Phishing** targets **many people** with the same generic message, hoping some will respond.

Shouldering (shoulder surfing)

Shouldering is observing a person's private information over their shoulder. This is a simple but effective technique where the attacker physically watches someone enter sensitive information.

Common targets for shouldering include:

- PIN numbers at cash machines
- Passwords being typed on computers or phones
- Lock screen patterns on mobile devices
- Sensitive documents being read on screens

Protection: Shield keypads when entering PINs, be aware of people standing too close, use privacy screens on laptops, and don't access sensitive information in crowded public places.

2.3 What is malware?

Malware is an umbrella term used to refer to a variety of forms of hostile or intrusive software. The term comes from "malicious software." Malware is designed to damage systems, steal data, or gain unauthorised access without the user's knowledge or consent.

Protecting against malware:

- Install and regularly update anti-virus/anti-malware software
- Keep operating systems and applications up to date with security patches
- Don't download software from untrusted sources
- Be cautious with email attachments, even from known contacts
- Don't click on suspicious links
- Regularly back up important data
- Use a firewall to monitor network traffic

2.4 Types of malware

Computer virus

A **computer virus** is malware that attaches itself to another program or file and spreads when that file is executed. Like biological viruses, computer viruses need a "host" to survive and replicate.

Key characteristics of viruses:

- **Attaches to files/programs:** The virus code is inserted into legitimate files
- **Requires execution:** The virus only activates when the infected file is run
- **Self-replicates:** Once active, it copies itself to other files and programs
- **Spreads through user action:** Users must run infected files for it to spread

Example: A virus attaches itself to a Word document. When a user opens the document, the virus activates and copies itself to other documents on the system. When these infected documents are shared with others (via email or USB drive), the virus spreads further.

Trojan

A **trojan** (or trojan horse) is malware that disguises itself as legitimate, useful software. Named after the Greek myth, trojans appear harmless or beneficial on the outside but contain malicious code inside.

Key characteristics of trojans:

- **Disguised as legitimate:** Appears to be useful software (game, utility, etc.)
- **User is tricked:** The victim willingly downloads and installs it
- **Activates when executed:** The malicious code runs when the user runs the program
- **Does NOT self-replicate:** Unlike viruses, trojans don't copy themselves to other files

Example: A user downloads what appears to be a free game. When they install and run it, it does function as a game, but it also secretly installs a backdoor that gives attackers remote access to the computer.

Spyware

Spyware is malware that secretly gathers information about a person's or organisation's computer activity without their knowledge. The collected information is then sent back to the attacker.

Key characteristics of spyware:

- **Runs secretly:** The user doesn't know it's there
- **Gathers information:** Monitors activity, keystrokes, browsing habits, etc.
- **Sends data to attacker:** Transmits collected information to a remote server
- **Operates in background:** Doesn't interfere with normal computer use to avoid detection

Example: Spyware installed on a computer might record every keystroke the user types, capturing passwords, credit card numbers, and private messages. This data is then sent to the attacker who can use it for identity theft or financial fraud.

```
MALWARE COMPARISON

+------------------+-------------------+-------------------+---------
|                  |      VIRUS        |      TROJAN       |     SPYWA
+------------------+-------------------+-------------------+---------
| How it arrives   | Attached to       | Disguised as      | Bundled w
|                  | infected files    | useful software   | other dow
+------------------+-------------------+-------------------+---------
| User action      | Must run infected | Must install the  | Often ins
| required         | file              | trojan program    | unknowing
+------------------+-------------------+-------------------+---------
| Self-replicates? | YES - copies to   | NO - does not     | NO - does
|                  | other files       | spread itself     | spread it
+------------------+-------------------+-------------------+---------
| Main purpose     | Damage, spread    | Create backdoor,  | Steal inf
|                  | to other systems  | gain access       | secretly
+------------------+-------------------+-------------------+---------
| Visible to user? | Often causes      | Appears to work   | Designed
|                  | noticeable damage | normally          | complete
+------------------+-------------------+-------------------+---------
```

Worked Example 5 — Describing blagging and phishing

Question: Blagging and phishing are social engineering techniques. Describe blagging and phishing. [4 marks]

Model answer:
Both: Both attempt to persuade a person to divulge private/sensitive information **(1)**, potentially leading to identity theft, financial theft, or unauthorised access **(1)**.
Blagging: Targets a specific individual using an invented/convincing scenario **(1)**.
Phishing: Targets many people via email/SMS/social media, disguised as being from a reputable source, often containing links to fake websites **(1)**.

Exam tip: This is a common 4-mark question. Get 2 marks for similarities (both are social engineering aiming to steal information) and 2 marks for differences (blagging = individual target, phishing = mass target).

Worked Example 6 – Describing malware types

Question: Viruses, trojans, and spyware are forms of malware. Describe how two of these forms of malware work. [4 marks]

Model answer:
Virus: Attaches itself to another program or file **(1)**. Spreads/replicates when the infected file is executed by the user **(1)**.
Trojan: Disguises itself as legitimate/useful software **(1)**. The user is tricked into installing it, and when executed, the malicious code activates **(1)**.

Exam tip: The mark scheme awards marks for the description, not naming the malware. Maximum 2 marks per type. Focus on HOW each works, not just WHAT it does.

Worked Example 7 – Defining social engineering

Question: Define the term social engineering. [1 mark]

Model answer:
Social engineering is the art of manipulating people so they give up confidential information **(1)**.

Exam tip: The key phrase is "manipulating people" — social engineering targets humans, not computer systems.

Worked Example 8 – Shouldering explanation

Question: Explain what shouldering (shoulder surfing) is and give an example. [2 marks]

Model answer:
Shouldering is observing a person's private information over their shoulder **(1)**. For example, watching someone enter their PIN at a cash machine **(1)**.

Exam tip: Shouldering is physical observation. Common examples include watching PIN entry, password typing, or reading screens in public places.

3. Prevention and detection methods

The AQA specification requires you to understand several security measures that help detect and prevent cyber security threats. These measures work best when used together as part of a layered security approach.

3.1 Biometric measures

Biometric measures use unique physical characteristics to verify a person's identity. Unlike passwords which can be forgotten, guessed, or stolen, biometric data is inherently tied to the individual.

Common biometric measures include:

- **Fingerprint recognition:** Scans the unique patterns on fingertips — common on smartphones and laptops
- **Facial recognition:** Analyses facial features — used on modern phones and security systems
- **Iris/retina scanning:** Scans the unique patterns in the eye — high security applications
- **Voice recognition:** Analyses voice patterns — used in phone banking and smart assistants

Advantages: Can't be forgotten like a password, difficult to fake, convenient for users, particularly useful for mobile devices where typing passwords is awkward.

Limitations: Can sometimes be fooled (e.g., by photos for basic facial recognition), cannot be changed if compromised (you can't get new fingerprints), privacy concerns about storing biometric data.

3.2 Password systems

Password systems require users to prove their identity by providing secret information (the password) that only they should know. Passwords are the most common form of authentication.

Effective password systems include:

- **Strong password requirements:** Minimum length, mix of characters, no common words
- **Account lockout:** Lock accounts after several failed attempts to prevent brute-force attacks
- **Password expiry:** Require regular password changes
- **Multi-factor authentication (MFA):** Combine password with another factor (like a code sent to your phone)

Good password practices: Use long, unique passwords for each account; consider using a password manager; never share passwords; don't write passwords down where others can find them.

3.3 CAPTCHA

CAPTCHA stands for "Completely Automated Public Turing test to tell Computers and Humans Apart." CAPTCHAs are challenges designed to be easy for humans but difficult for computer programs (bots) to solve.

CAPTCHAs protect against:

- **Automated account creation:** Prevents bots from creating thousands of fake accounts
- **Spam:** Stops bots from posting automated messages on forums or comments
- **Brute-force attacks:** Slows down automated password guessing
- **Web scraping:** Prevents automated harvesting of data from websites

Common CAPTCHA types include: identifying distorted text, selecting images that match a description ("click all the traffic lights"), or simply clicking a checkbox (which analyses mouse movement patterns).

3.4 Email confirmations

Email confirmations verify that a user has access to the email address they claim to own. When creating an account or performing sensitive actions, the system sends an email to the registered address containing a link or code that must be used to confirm the action.

Email confirmations help by:

- **Preventing fake account creation:** Users must have access to a real email address
- **Confirming identity:** If someone tries to change your account details, you'll receive an email alert
- **Stopping bots:** Automated systems struggle to access email accounts to confirm
- **Reducing spam accounts:** Creating accounts requires more effort

The security relies on the assumption that only the legitimate user has access to their email account — this is why securing your email account is so important.

3.5 Automatic software updates

Automatic software updates ensure that security patches are installed as soon as they become available, without requiring the user to manually check for and install updates.

Why automatic updates matter:

- **Patches known vulnerabilities:** Updates fix security flaws that attackers know about and are actively exploiting
- **Removes user burden:** Users don't need to remember to check for updates
- **Faster protection:** Security fixes are applied immediately rather than waiting weeks or months
- **Consistent protection:** All users receive updates at the same time

Many cyber attacks succeed because victims are running software with known vulnerabilities that patches were available for. Once a vulnerability becomes public knowledge, attackers quickly develop tools to exploit it — organisations that haven't applied the available patch become easy targets.

3.6 Combining security measures

Effective cyber security uses multiple layers of protection. No single measure is perfect, but combining them creates defence in depth:

```
LAYERED SECURITY APPROACH

    +-------------------------------------------------------------+
    |                    AUTOMATIC UPDATES                        |
    |         (Keep software patched against known threats)       |
    +-------------------------------------------------------------+
                              |
    +-------------------------------------------------------------+
    |                    PASSWORD + BIOMETRICS                    |
    |        (Verify user identity before granting access)        |
    +-------------------------------------------------------------+
                              |
    +-------------------------------------------------------------+
    |                    CAPTCHA + EMAIL CONFIRMATION             |
    |         (Verify user is human and owns their account)       |
    +-------------------------------------------------------------+
                              |
    +-------------------------------------------------------------+
    |                    USER TRAINING                            |
    |      (Educate users about social engineering threats)       |
    +-------------------------------------------------------------+

    Each layer stops different types of attacks.
    If one layer fails, others still provide protection.
```

Worked Example 9 — CAPTCHA purpose

Question: Explain how CAPTCHA is used to improve website security. [2 marks]

Model answer:
CAPTCHA is a test that checks if the user is human and not a computer program/bot **(1)**. This prevents automated attacks such as bots creating fake accounts or submitting spam **(1)**.

Exam tip: CAPTCHA is about distinguishing humans from bots. Focus on what it prevents: automated account creation, spam, brute-force attacks.

Worked Example 10 — Email confirmations

Question: Explain how email confirmations help to protect website accounts. [2 marks]

Model answer:
Email confirmations send a link/code to the registered email address when an account is created **(1)**. This confirms the user's identity by checking they have access to the email address, preventing fake or unauthorised accounts **(1)**.

Exam tip: The key point is verification — email confirmations prove the user actually owns/controls the email address they claim.

Worked Example 11 – Biometric advantages

Question: State two advantages of using biometric measures for mobile device security. [2 marks]

Model answer:
Biometric data cannot be forgotten like a password **(1)**. Biometric data is difficult to fake or steal, making it more secure than passwords **(1)**.
Alternative answers: More convenient/faster than typing passwords; unique to the individual; can't be guessed or brute-forced.

Exam tip: The specification mentions biometrics "particularly for mobile devices" — common advantages relate to convenience (no typing on small screens) and security (can't be observed over shoulder like a PIN).

Worked Example 12 – Automatic updates importance

Question: Explain why automatic software updates are important for cyber security. [2 marks]

Model answer:
Automatic updates install security patches as soon as they become available **(1)**. This fixes known vulnerabilities before attackers can exploit them, without requiring user action **(1)**.

Exam tip: Link updates to vulnerabilities — updates fix security flaws. Emphasise "automatic" means no delay waiting for users to manually update.

Worked examples summary

The worked examples throughout this topic cover the main exam question styles you'll encounter. Here's a summary of what each example demonstrates:

Example	Topic	Marks	Skill tested
1	Defining cyber security	2	Recall of specification definition
2	Explaining pharming	2	Description of threat
3	Penetration testing types	4	Compare and describe
4	Unpatched software threat	2	Explanation with reasoning
5	Blagging vs phishing	4	Compare social engineering methods
6	Malware types	4	Describe how malware works
7	Defining social engineering	1	Recall definition
8	Shouldering explanation	2	Define with example
9	CAPTCHA purpose	2	Explain security measure
10	Email confirmations	2	Explain security measure
11	Biometric advantages	2	State advantages
12	Automatic updates	2	Explain importance

Quick reference

Key definitions

Term	Definition (mark-scheme style)
Cyber security	The processes, practices, and technologies designed to protect networks, computers, programs, and data from attack, damage, or unauthorised access.
Social engineering	The art of manipulating people so they give up confidential information.
Malware	An umbrella term for hostile or intrusive software (malicious software).
Pharming	A cyber attack that redirects a website's traffic to a fake website.
Penetration testing	The process of attempting to gain access to resources without knowledge of usernames, passwords, or other normal means of access.

Social engineering methods

Method	Definition	Key point
Blagging	Creating an invented scenario to trick a specific person into divulging information	Targets an **individual**
Phishing	Fraudulently obtaining information via email/SMS, disguised as from a reputable source	Targets **many people**
Shouldering	Observing someone's private information over their shoulder	**Physical** observation

Malware types

Type	How it works	Key characteristic
Virus	Attaches to files; spreads when executed	**Self-replicates**
Trojan	Disguises as legitimate software	User **tricked into installing**
Spyware	Secretly gathers information	Runs **without user knowledge**

Prevention methods

Method	What it does	Protects against
Biometrics	Uses physical characteristics (fingerprint, face)	Unauthorised access
Password systems	Requires secret credentials	Unauthorised access
CAPTCHA	Tests user is human, not bot	Automated attacks
Email confirmations	Verifies user owns email address	Fake account creation
Automatic updates	Installs security patches automatically	Known vulnerabilities

Threats summary

Human-targeted threats:

- Blagging (targets individual)
- Phishing (targets many)
- Shouldering (physical observation)

System-targeted threats:

- Malware (viruses, trojans, spyware)
- Pharming (redirects to fake sites)

- Exploiting unpatched software

Typical pitfalls

Pitfall 1 — Confusing blagging and phishing.
Wrong: Treating them as the same thing.
Right: Blagging targets a specific individual; phishing targets many people with the same message.

Pitfall 2 — Confusing virus and trojan.
Wrong: Saying trojans self-replicate.
Right: Only viruses self-replicate. Trojans disguise themselves as legitimate software but don't spread on their own.

Pitfall 3 — Vague malware descriptions.
Wrong: "A virus damages your computer."
Right: Describe HOW it works: "A virus attaches to files and spreads when those files are executed."

Pitfall 4 — Confusing pharming with phishing.
Wrong: Treating them as the same because both involve fake websites.
Right: Phishing tricks users into clicking fake links; pharming redirects traffic even when users type the correct address.

Pitfall 5 — Forgetting what CAPTCHA stands for.
Wrong: Vaguely describing it as "a security check."
Right: CAPTCHA tests that the user is human, not a bot/automated program.

Pitfall 6 — Wrong penetration testing definitions.
Wrong: Describing it as actual hacking by criminals.
Right: Pen testing is authorised testing by ethical hackers to find vulnerabilities before attackers do.

Pitfall 7 — Incomplete social engineering definition.
Wrong: "Hacking into computers."
Right: Social engineering manipulates PEOPLE, not computers. It exploits human psychology, not software.

Pitfall 8 — Missing the "secret" aspect of spyware.
Wrong: Just saying "spyware collects information."
Right: Emphasise that spyware operates WITHOUT the user's knowledge and SENDS data to the attacker.

Pitfall 9 — Forgetting automatic updates benefit.
Wrong: "Updates add new features."
Right: Focus on security: automatic updates install security patches to fix known vulnerabilities.

Pitfall 10 — Confusing pen test types.
Wrong: Getting white box and black box mixed up.
Right: White box = tester has knowledge (insider); Black box = tester has NO knowledge (external attacker).

Assessment Hub | Long-Answer | Notes Index

Williams Physics Education — over **1,100,000+ marks** of exam-aligned content and **4,200+ auto-marked assessments** across 67 qualifications at GCSE, A-Level, AP & Professional Qualifications. Free to use, no login required.

About & Contact • Privacy • Terms • Accessibility • Copyright • DMCA • YouTube

WPE is free for everyone. If our resources help you or your students, you can support the project here.

© 2026 Williams Physics Education. All rights reserved.